CASE STUDY

SSHole: The OpenSSH Authentication Bypass of November 2026 (CVE-2026-123158)

A TeamStarWolf case study. Published 11 November 2026; every source checked as of that date.

Executive summary

This is a story about how fast an open-source community can move when it has to. On 4 November 2026 the OpenSSH maintainers learned that, on some Linux systems, sshd would accept a password login it should have refused (**Confirmed** [2]). The fix commit was authored at 21:18 UTC the same day (**Confirmed** [4]). By the next day OpenSSH had shipped Portable 10.6p2, Alpine Linux had published fixed packages for every branch back to 3.16 and four point releases, the musl maintainer had posted his own advisory, and the disclosure was on oss-security (**Confirmed** [1] [13] [14] [7] [6]). Gentoo, Void Linux, OpenWrt, Buildroot and OpenEmbedded picked up the fix within about a day (**Confirmed** [20] [21] [22] [24] [25]). The flaw was reported by Ozgun Kultekin of Wakefield (**Confirmed** [1]); the oss-security subject line spells it "sshole", the researcher's site is sshhole.com, and the press wrote SSHole (**Confirmed** [6]; **Reported** [40] [47]).

The flaw is narrow. It affects OpenSSH on Linux built against the musl C library and run without PAM, with password authentication on, and only for an account whose password field is a single asterisk while another local account holds a SHA-256 or SHA-512 crypt hash (**Confirmed** [13]; the musl and PAM scope also [7] [10]). Alpine Linux is the named example (**Confirmed** [10]). Red Hat and Ubuntu, whose builds use glibc and PAM, and SUSE say their products are not affected (**Confirmed** [15] [18] [19]). Where the conditions hold, though, an attacker who can reach the SSH port and knows an eligible account name logs in without a password, in one connection, reliably (**Confirmed** [13]).

The MITRE CVE Numbering Authority published CVE-2026-123158 at 15:46 UTC on 5 November, scored 8.1 High with CWE-394 (**Confirmed** [10]). Honeypot operators reported exploitation attempts within hours of the CVE (**Reported** [43] [42]) Previdian told Help Net Security on 6 November that it had root access on an Alpine honeypot (**Reported** [44]), and GreyNoise confirmed its first successful exploitation of one of its own sensors

at 00:46 UTC on 7 November (**Reported** [41]). CISA added the CVE to the Known Exploited Vulnerabilities catalog on 9 November with a three-day deadline under Binding Operational Directive 26-04 and a forensic triage requirement (**Confirmed** [34] [35]). It is the only OpenSSH CVE in KEV (**Confirmed** [35]).

This study sets out the technical record at advisory level, a dated timeline from the fix to the KEV deadline, what the sensor networks saw and what they did not, the exposure picture across distributions, cloud images, containers and embedded builds, the vulnerability-management lessons, the defender playbook, the lineage of earlier OpenSSH flaws it belongs to, and the MITRE ATT&CK, CWE and D3FEND bindings with a Navigator layer.

Key facts at a glance

Field	Value
Identifier	CVE-2026-123158 [10]; GitHub advisory GHSA-4fcc-vm97-gx3x [12]; EUVD-2026-117552 (as listed by SUSE) [19]
Name	SSHole, also spelled `sshole`, `*sshole` and sshhole in the record [6] [20] [40]
Product	sshd in OpenSSH Portable before 10.6p2, on Linux, with musl libc and without PAM [10] [1]
Class	Password authentication bypass. CNA weakness CWE-394 (Unexpected Status Code or Return Value) [10]; Red Hat maps CWE-303 [15]
Severity	CVSS 3.1 8.1 High, `AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H` (CNA) [10]; Red Hat draft 9.8 Critical [15]; NVD shows the CNA score only [11]
SSVC (CISA ADP)	Exploitation active, Automatable no, Technical Impact total [10]
Fixed	OpenSSH 10.6p2, 5 November 2026 [1]; Alpine point releases 3.21.10, 3.22.8, 3.23.8 and 3.24.4, plus fixed packages back to 3.16 [13] [14]
Fix commit	openssh-portable `4353fdc`, "avoid password authn bypass", authored 4 November 2026 21:18 UTC [4]
Not affected (vendor statements)	Red Hat, Ubuntu, SUSE, Synology; non-Linux systems; glibc systems; PAM password logins; Dropbear [15] [18] [19] [27] [2] [7]
KEV	Added 9 November 2026, due 12 November 2026, forensic triage Yes, ransomware use Unknown [34] [35]
Exploitation	Active per CISA [34] [10]; 26 confirmed post-exploitation chains on one sensor network by 11 November [41] (Reported)
Attribution	None. No opened primary names a threat actor or a country [41] (Inferred)
Credit	Ozgun Kultekin of Wakefield, and the Alpine developers [1] [2]

Key findings

- **The fix came before the CVE.** The fix commit was authored at 21:18 UTC on 4 November, the day OpenSSH learned of the bug, and 10.6p2 shipped on 5 November; the CVE record followed at 15:46 UTC that day and the 10.6p2 release notes carry no CVE id (**Confirmed** [4] [2] [1] [10]). OpenSSH said it released quickly because AI agents had rediscovered bugs within hours, and that it now regards long embargoes as mainly benefiting attackers (**Confirmed** [2]).

- **Three parties, three readings of the root cause.** OpenSSH says the root cause is outside sshd but exploitable and avoidable there (**Confirmed** [1]). The oss-security disclosure describes the mechanism: for an account whose password field is `*`, a long password makes musl's `crypt(3)` return `*` (**Confirmed** [6]). The musl maintainer calls it erroneous use by the caller, not a musl bug, and expects musl's error mechanism to change (**Confirmed** [7] [8]). Alpine's summary explains the collision: musl's `crypt()` returns `*` as an error indicator for an over-long key, and that matches a passwordless account's `*` field (**Confirmed** [13]).
- **The conditions are specific, and common in one ecosystem.** All four must hold: sshd without PAM, `PasswordAuthentication yes` (the default), an account whose password field is `*`, and a `$5$` or `$6$` hash on some other local account (**Confirmed** [13]). Alpine ships root as `root:*` since about 3.16, and its tiny-cloud images from 3.18.11 to 3.24.3 ship an `alpine` user with a `*` field and passwordless doas (**Confirmed** [13]).
- **Attempts came within hours; confirmed compromise came later and only on sensors.** Previdian saw a first attempt about 8 hours after CVE publication and told Help Net Security on 6 November of root access on an Alpine honeypot; SANS ISC saw attempts on 5 November; GreyNoise's first confirmed successful chain came about 32 hours after NVD publication (**Reported** [43] [44] [42] [41]; the comparison is Inferred).
- **Scan volume is not compromise.** GreyNoise counted 33.7 million attempted SSH sessions on its sensors from 5 to 11 November, 5 possible exploitation attempts and 26 confirmed post-exploitation chains from 8 attacker addresses (**Reported** [41]).
- **The trackers disagree, in both directions.** Red Hat shows a preliminary 9.8 and CWE-303 while saying its products are not affected; Debian marks glibc releases vulnerable at urgency "unimportant"; Ubuntu rates the CVE High solely because it is in KEV while listing every release Not affected (**Confirmed** [15] [17] [18]). NVD's CPE configuration names only Alpine (**Confirmed** [11]).
- **The hard-to-see population is embedded.** Medcrypt reports reproducing the flaw on a stock Yocto image and calls musl without PAM, with password authentication and `*`-locked service accounts, a common hardened embedded baseline (**Reported** [9]). No vendor advisory or CPE entry covers those builds (Inferred from [11]).
- **Patching the package is not enough.** Upgrading the package does not replace the running daemon; sshd must be restarted (**Confirmed** [13]).

Top recommendations

1. On every Linux host that runs OpenSSH on musl (Alpine, Yocto, Buildroot, OpenWrt with the openssh package, Alpine-based containers that run sshd), upgrade to 10.6p2 or the patched distribution package, then restart sshd [1] [13].
2. Where that cannot happen today, set `PasswordAuthentication no`, after confirming key-based login works and while keeping an existing session open, then restart sshd [13] [7].
3. Decide exposure by the four Alpine conditions and the libc, not by the OpenSSH version string: Alpine backported the fix into older version strings, and glibc and PAM hosts flagged by version are not exploitable [13] [15] [18].
4. For internet-facing hosts, treat the KEV due date of 12 November 2026 as the deadline and perform forensic triage, as the KEV entry requires [34] [37].

5. Hunt for sshd "Accepted password" log lines for accounts that have no password, review doas use, new users, changed files and authorized keys, and treat a host as compromised if a login cannot be ruled out [13].
6. Rotate any credentials and SSH keys a compromised host could read, and remove attacker-added keys and accounts before returning it to service [41] [13] (Inferred from the reported post-exploitation).

Scope and method

This study covers CVE-2026-123158 from the OpenSSH fix of 4 November 2026 to the state of the public record on 11 November 2026, the day before the KEV due date. It draws on the OpenSSH release notes, mailing-list post and fix commit; the oss-security and musl mailing lists; the CVE, NVD, GitHub Advisory Database and KEV records; CISA's alert and BOD 26-04; the Canadian Centre for Cyber Security and HKCERT; the Alpine, Red Hat, Debian, Ubuntu, SUSE, Gentoo, Void Linux, OpenWrt, Buildroot, OpenEmbedded, FreeBSD and Synology records; downstream container and add-on projects; the sensor operators GreyNoise, SANS ISC and Previdian; press reports; the live MITRE ATT&CK pages; and the library's own data files. Every source was opened on 11 November 2026. Quotations are kept to a few words.

Tradecraft is described at the level the advisories use. This study does not reproduce the trigger condition beyond "an over-long password", any exploit code, attacker addresses, command-and-control names or key material. Two public reproduction repositories are referenced by the CVE record; their existence is recorded and their contents were not reviewed [10] [51]. No lab reproduction was run for this study.

Grade	Meaning
Confirmed	Taken from an opened primary: the OpenSSH project, the musl maintainer, a distribution or vendor advisory, a commit, the CVE, NVD, GitHub advisory or KEV record, a government advisory or directive, the MITRE ATT&CK page, or the library's data files
Reported	A sensor operator's own telemetry, a researcher's own write-up, or press coverage. Sensor counts are graded Reported throughout because what each operator counts as an attempt or a success rests on its own published method and cannot be checked independently
Demonstrated	A reproduction others can check. No item here is graded Demonstrated: the public reproduction repositories were not reviewed
Inferred	This study's own reasoning from the cited facts, labelled where it appears; every ATT&CK mapping in Part 8 is this study's own and is Inferred

Where two opened sources give the same fact different weight, the study uses the more conservative grade. Where sources disagree on a fact (exploit timing, the number of connections needed, the CVSS vector), the study prints both and says so.

Part 1: The technical record

What OpenSSH says

OpenSSH Portable 10.6p2 was released on 5 November 2026. Its notes say it contains a critical security workaround for Linux systems that use musl libc with PAM disabled (**Confirmed** [1]). The single Security entry says sshd now avoids a password authentication bypass that affects some Linux systems built and run without PAM, and that the project considers the root cause to lie outside sshd, though it is exploitable through sshd and avoidable there (**Confirmed** [1]). The previous release, 10.6p1, had shipped on 6 October 2026 (**Confirmed** [1]).

Damien Miller's mail to openssh-unix-dev, "urgent security release: 10.6p2", told operators of musl Linux systems without PAM to set `PasswordAuthentication=no` or disable SSH immediately, and said the bug does not exist on non-Linux systems, on Linux with glibc, or on Linux systems that use PAM for password authentication (**Confirmed** [2]). He posted the same announcement on Mastodon at 09:03:46 UTC on 5 November (**Confirmed** [3]).

The fix

The fix is openssh-portable commit `4353fdc43ef646c43a8dda7025cc1a898caf1482`, "avoid password authn bypass", by Damien Miller, authored at 21:18 UTC and committed at 21:57 UTC on 4 November 2026 (**Confirmed** [4]). It changes `auth-passwd.c`, `openbsd-compat/port-uw.c` and `openbsd-compat/xcrypt.c`, and its message says the root cause is not within OpenSSH (**Confirmed** [4]). Password checking now works on private copies of the stored hash and rejects a match when the stored hash is shorter than a minimum length (**Confirmed** [4]); the oss-security disclosure describes the same change as a check for a minimum valid hash length (**Confirmed** [6]).

Why it happens, at advisory level

Alpine's root-cause summary is the clearest. Without PAM, sshd compares the `crypt()` of the login attempt with the stored password field, and when the stored field is too short to carry a salt it borrows another account's salt. musl's `crypt()` returns `*` as an error indicator for an over-long key, and that string matches the `*` field of a passwordless account (**Confirmed** [13]). The CVE record puts the same thing in weakness terms: the bypass relates to misreading whether a string is a password hash, and for some account configurations an over-long password succeeds (**Confirmed** [10]). The musl maintainer adds that musl's failure token, `*`, is the conventional shadow "no password" value, and proposes changing musl's tokens to `*0` and `*1` (**Confirmed** [8]).

The researcher's write-up says he found the bug about four days after an OpenSSH commit of 30 October 2026 that touched `pick_salt()`, that it ran about 17,600 test logins in which only musl without PAM accepted the invalid passwords, and that the bug has existed since 2016 with the musl behavior dating to 2012 (**Reported** [40]). The researcher, The Hacker News and Help Net Security trace SSHole to the fake-salt handling OpenSSH added in 2016 for CVE-2016-6210 (**Reported** [40] [45] [44]; the 2016 fix itself is **Confirmed** [1], see Part 7).

Who says the root cause is theirs

Party	Position	Source
OpenSSH	Root cause outside sshd; exploitable through sshd and avoidable there; fixed by a workaround in sshd	[1] [4] (Confirmed)
oss-security disclosure (Jan Schaumann)	Describes the mechanism (musl `crypt(3)` returning `*`) and quotes OpenSSH on the root cause; does not assign it; fix checks for a minimum valid hash length; mitigation is `PasswordAuthentication no`	[6] (Confirmed)
musl (Rich Felker)	Erroneous use by the caller, not a musl bug; the crypt error mechanism will likely change in the next release cycle	[7] [8] (Confirmed)
Red Hat	CWE-303, Incorrect Implementation of Authentication Algorithm	[15] (Confirmed)
CVE record (MITRE CNA)	CWE-394, Unexpected Status Code or Return Value	[10] (Confirmed)

All of these can be true at once: a C library returned a legitimate but unexpected value, and a caller treated it as a hash (Inferred).

The conditions, as Alpine states them

Alpine says a host is affected only when all of the following hold (**Confirmed** [13]):

1. It runs `openssh-server` built without PAM, or `openssh-server-pam` with `UsePAM no`.
2. `PasswordAuthentication` is `yes`, which is the default.
3. An account has `*` as its password field.
4. At least one local account has a `$5$` or `$6$` password hash.

Alpine lists the accounts that carry `*`: root (shipped as `root:*` since about 3.16 and protected by the default `PermitRootLogin prohibit-password`), key-only users, directory-service users through musl-nscd, and the tiny-cloud `alpine` user (**Confirmed** [13]). It lists as not affected: containers that do not run sshd, `PasswordAuthentication no`, `openssh-server-pam` with `UsePAM yes`, accounts locked with `!`, hosts with no `$`-style hash, and cloud-init images, because cloud-init writes `PasswordAuthentication no` (**Confirmed** [13]).

What an attacker gets

Alpine says an attacker who can reach the SSH port and knows an eligible account name can log in without a password, in one connection and reliably (**Confirmed** [13]). Access carries the compromised account's permissions (**Reported** [45]). Root is not reached directly under the default `PermitRootLogin prohibit-password` (**Confirmed** [13]). The tiny-cloud images are the exception that matters: their `alpine` user has passwordless doas, so the images are safe on first boot but become exploitable, with a path to root, once any `$6$` hash exists on the machine (**Confirmed** [13]). The researcher says the same of Alpine's official AWS and Azure images (**Reported** [40]).

Disagreements in the record

- **One connection or two.** Alpine says one connection, reliably (**Confirmed** [13]). Medcrypt's oss-security post mentions a two-attempt requirement (**Reported** [9]). The study does not resolve this; both are printed.

- **CVSS vector.** The CNA scores attack complexity High (8.1); Red Hat's draft scores it Low (9.8) (**Confirmed** [10] [15]). The four preconditions above argue for the CNA's AC:H reading on most hosts, and for Red Hat's on a tiny-cloud instance that already holds a `$6$` hash (Inferred).
- **Name.** The oss-security subject says `sshole`, Gentoo's bug title `*sshole`, the researcher's site sshhole.com, and the press SSHole (**Confirmed** [6] [20]; **Reported** [40] [47]).
- **When the public exploit appeared.** GreyNoise's timeline puts the first public exploit on GitHub at 13:16:55 UTC on 5 November, about four hours after the fix went public and about 2.5 hours before the CVE id was reserved (**Reported** [41]). Previdian's timeline puts a public proof of concept at 17:30 UTC (**Reported** [43]).

Part 2: The timeline

All times are UTC. Each row is one dated event in the opened record.

Date and time	Event	Grade	Source
2016-08-01	OpenSSH 7.3 fixes CVE-2016-6210, a long-password timing user-enumeration flaw, and caps password length at 1024 characters	Confirmed	[1]
2026-06-10	CISA issues BOD 26-04, superseding BOD 19-02 and BOD 22-01	Confirmed	[37]
2026-10-06	OpenSSH 10.6 (10.6p1) released	Confirmed	[1]
2026-10-30	OpenSSH commit touching `pick_salt()`, per the researcher	Reported	[40]
2026-11-01	Alpine 3.21 reaches end of support; SANS ISC honeypots log long-password entries that came from broken brute-force scripts, not SSHole	Confirmed; Reported	[13] [42]
about 2026-11-03	The researcher says he found the bug about four days after the 30 October commit	Reported	[40]
2026-11-04	OpenSSH learns of the problem	Confirmed	[2] [47]
2026-11-04 21:18	Fix commit `4353fdc` authored (committed 21:57)	Confirmed	[4]
2026-11-05 01:51	OpenWrt packages feed commit "openssh: update to 10.6_p2" authored, signed off by Darren Tucker (committed 14:09)	Confirmed	[23]
2026-11-05 09:00	The fix goes public, per GreyNoise's timeline	Reported	[41]
2026-11-05 09:03	Damien Miller's Mastodon announcement	Confirmed	[3]
2026-11-05	OpenSSH 10.6p2 released; "urgent security release" mail to openssh-unix-dev	Confirmed	[1] [2]
2026-11-05	Alpine advisory; fixed packages for every branch from edge back to 3.16; point releases 3.21.10, 3.22.8, 3.23.8 and 3.24.4	Confirmed	[13] [14]

Date and time	Event	Grade	Source
2026-11-05	oss-security disclosure, "sshole", by Jan Schaumann; musl maintainer's advisory on the musl list	Confirmed	[6] [7]
2026-11-05 10:52	linuxserver `openssh-server` image `10.3_p1-r2-ls242` published, matching Alpine 3.24's fixed package version	Confirmed (fix inferred from the version match)	[30]
2026-11-05 12:19	Researcher write-up published, per GreyNoise's timeline	Reported	[41]
2026-11-05 13:16	First public exploit on GitHub, per GreyNoise's timeline	Reported	[41]
2026-11-05 15:46	MITRE CNA reserves and publishes CVE-2026-123158	Confirmed	[10]
2026-11-05 16:17	NVD publishes the CVE	Confirmed	[11]
2026-11-05 17:01	Buildroot "package/openssh: security bump version to 10.6p2"	Confirmed	[24]
2026-11-05 17:30	Public proof of concept, per Previdian's timeline	Reported	[43]
2026-11-05 18:33	GHSA-4fcc-vm97-gx3x published, unreviewed, high at 8.1	Confirmed	[12]
2026-11-05 18:34	GreyNoise's first CVE-2026-123158 tag hit among the listed addresses	Reported	[41]
2026-11-05 20:35	google/goonami-scanner PR #277 merged, adding the CVE id to the existing `opensshauthbypass` detector	Confirmed	[33]
2026-11-10 04:55	CISA ADP container on the CVE record last updated: SSVC Exploitation active, Automatable no, Technical Impact total (date-only timestamp 5 November)	Confirmed	[10]
2026-11-05	Gentoo bug 985742 opened and openssh 10.6_p2 added; Void Linux and the OpenWrt feed move to 10.6p2; Home Assistant's Terminal & SSH app 10.6.0 and the community SSH add-on v24.2.1 ship Alpine's fixed package	Confirmed	[20] [21] [22] [28] [29]
2026-11-05	Canadian Centre for Cyber Security issues AV26-1130	Confirmed	[38]
2026-11-05	Public reproduction repositories `leonjza/sshhole-lab` and `predkambrij/sshhole-repro` created	Confirmed (existence only)	[51] [10]
2026-11-05	SANS ISC sees its first SSHole exploit attempt; 232 long-password attempts that day	Reported	[42]
2026-11-06 00:05	Previdian's first sensor observation, about 8 hours after CVE publication	Reported	[43]
2026-11-06 10:15	OpenEmbedded-Core "openssh: upgrade 10.6p1 -> 10.6p2"	Confirmed	[25]

Date and time	Event	Grade	Source
2026-11-06	Ubuntu publishes the CVE at priority High because it is in KEV, with every release Not affected	Confirmed	[18]
2026-11-06	Synology-SA-26:16 says no Synology product is affected; HKCERT bulletin rates the flaw High Risk	Confirmed	[27] [39]
2026-11-06	musl maintainer explains the `*` collision and proposes new failure tokens	Confirmed	[8]
2026-11-06	SecurityWeek reports no exploitation yet; Help Net Security reports Previdian's root access on an Alpine honeypot; watchTowr ties exploitation to botnets and cryptomining	Reported	[47] [44] [46]
2026-11-06	SANS ISC peak: 713 long-password attempts	Reported	[42]
2026-11-07 00:46	GreyNoise's first observed successful exploitation, an sshd-to-shell chain on one of its sensors, about 32 hours after NVD publication	Reported	[41]
2026-11-07	GreyNoise's GT10 cluster begins the first of two intrusions; doas attempts to read the shadow file begin	Reported	[41]
2026-11-07	panubo/docker-sshd issue #93 asks for OpenSSH 10.6p2; Coolify discussion #12484 proposes hardening its Alpine install path	Confirmed; Reported	[31] [32]
2026-11-08	SANS ISC diary 33498 published (51 attempts that day); SUSE publishes TID-SSHHOLE; Previdian counts 20 attempts from 13 addresses in nine countries; GreyNoise records a key replacement on an `alpine` account	Reported; Confirmed (SUSE)	[42] [19] [45] [41]
2026-11-09	CISA adds the CVE to KEV with three others "based on evidence of active exploitation"; due date 12 November	Confirmed	[36] [34]
2026-11-09	CCCS AV26-1130 Update 1 notes the KEV addition	Confirmed	[38]
2026-11-09	Medcrypt posts an independent reproduction, including on a stock Yocto image	Reported	[9]
2026-11-09	BleepingComputer, Check Point Research and SecurityWeek report exploitation	Reported	[46] [49] [48]
2026-11-10	CVE record and NVD last updated; NVD status Analyzed with the KEV dates	Confirmed	[10] [11]
2026-11-10	RHSA-2026:97866, an openssh update for RHEL 9 that fixes three unrelated CVEs, not this one	Confirmed	[16]
2026-11-10	KEV catalog version 2026.11.10 carries the entry; HKCERT updates its bulletin	Confirmed	[35] [39]
2026-11-10	GreyNoise records creation of a local account with a doas rule for passwordless root, followed by removal of its home directory	Reported	[41]
2026-11-11 05:10	GreyNoise page update: 26 confirmed post-exploitation chains from 8 attacker addresses	Reported	[41]
2026-11-11	Previdian's 7-day telemetry: 26 attempts from 17 addresses in 12 countries across 4 sensors	Reported	[43]

Date and time	Event	Grade	Source
2026-11-12	KEV due date	Confirmed	[34]

The span from fix commit to KEV due date is eight days (Inferred from [4] [34]).

Part 3: Who exploited it

What the government record says

CISA's alert of 9 November added four KEV entries "based on evidence of active exploitation", among them CVE-2026-123158 (**Confirmed** [36]). The CVE record's CISA ADP container rates exploitation active and cites GreyNoise and the SANS ISC diary as third-party advisories (**Confirmed** [10]). HKCERT's bulletin notes exploitation in the wild and a public proof of concept (**Confirmed** [39]). KEV sets known ransomware campaign use to Unknown (**Confirmed** [34]).

What the sensor networks saw

Three sensor operators published their own counts. Each counts something different, and none names a victim organization.

Operator	What it counted	Figures	Source
GreyNoise	Its own sensors, 5 November 09:00 to 11 November 05:10 UTC	45.5 million TCP/22 SYN scans; 34.3 million full connections; 33.7 million attempted SSH sessions; 5 possible exploitation attempts; 26 confirmed post-exploitation chains from 8 attacker addresses; first success 7 November 00:46:51	[41] (Reported)
SANS ISC (Johannes Ullrich)	Long-password attempts on Cowrie honeypots, which keep only the first 255 password characters	58 on 4 November, 232 on 5 November, 713 on 6 November, 246 on 7 November, 51 on 8 November; first real SSHole attempt on 5 November; no success confirmed in the diary, though the author expects some attempts succeeded	[42] (Reported)
Previdian	Exploitation attempts on its sensors	First attempt about 8 hours after CVE publication; 20 attempts from 13 addresses in nine countries by 8 November; 26 attempts from 17 addresses in 12 countries across 4 sensors by 11 November, labelled attempts, not confirmed compromises	[43] [45] (Reported)

Previdian's founder, Ryan Dewhurst, told Help Net Security that the first attempt came less than nine hours after CVE publication, that Previdian confirmed root access on a honeypot running real Alpine Linux and OpenSSH, and that all eight early attempts came from one address geolocated to Japan, followed by basic reconnaissance over non-interactive SSH (**Reported** [44]). Previdian's own page does not state the honeypot root, and it is internally inconsistent on one date (its evidence section says 5 November where its KEV source table says 6 November 09:53 UTC) (**Reported** [43]). Check Point's 9 November threat intelligence report also mentions successful root access against an Alpine honeypot (**Reported** [49]). SANS lists several addresses in Korea Telecom's AS4766 among its top sources (**Reported** [42]); GreyNoise lists attacker source networks in Indonesia, Egypt, Spain, China, Hong Kong, Singapore and the Philippines (**Reported** [41]).

An earlier GreyNoise snapshot, quoted by BleepingComputer, gave 16 successful chains from six addresses and 27.5 million port-22 scans and 20.1 million SSH sessions, which the article says were not confirmed SSHole attacks (**Reported** [46]).

What attackers did after login

GreyNoise reports, at technique level (**Reported** [41]):

- host, network, process and SSH-configuration discovery, and `sshd-session` spawning `sh`;
- cloud instance metadata queries;
- repeated attempts, from 8 to 10 November, to add attacker SSH keys to the root and `alpine` authorized keys, including one key replacement on `alpine` on 8 November;
- doas attempts to read the shadow file from 7 November;
- creation of a local account with a doas rule for passwordless root on 10 November, followed by removal of its home directory;
- name-resolution (DNS configuration) changes, a backdoor SSH server, a startup service for persistence, and a Python agent polling an HTTPS command-and-control server.

BleepingComputer, citing GreyNoise, adds attempts to read password hashes and root SSH keys (**Reported** [46]). The Hacker News reports discovery commands over non-interactive sessions (**Reported** [45]).

The GT10 cluster and the TAC Agent

GreyNoise tracks a "major" activity cluster it calls GT10: two intrusions and seven addresses, some of them possibly compromised infrastructure, on 7 and 8 November (**Reported** [41]). It says not all SSHole activity is GT10 and names no actor or country (**Reported** [41]). GT10's intrusions ran discovery and network tests, staged tools, changed name resolution, started a backdoor SSH server and dropped a Python runtime with a "TAC Agent": a standard-library Python 3 implant, version 0.1.1, with a shared hard-coded enrollment token, a beacon of about 150 seconds and unsigned self-update, whose enrollment never succeeded on the first victim (**Reported** [41]). The agent's comments and logs are in Chinese (**Reported** [41]). GreyNoise flags its TAC Agent analysis as LLM-generated and some GT10 evidence as medium confidence (**Reported** [41]). BleepingComputer reported that the Chinese-language comments may aid attribution alongside other evidence (**Reported** [46]).

Attribution: none

No opened primary names a threat actor or attributes the activity to a country. GT10 is an activity cluster, and Chinese-language strings in a tool are an artifact, not attribution (Inferred [41]). watchTowr's Jake Knott said that so far only botnets and crypto miners had adopted the flaw, and Defused saw a small number of actors, not widespread activity (**Reported** [48] [46]); both firms' original posts could not be opened. No ATT&CK group, software or campaign object applies (Inferred; see Part 8).

Part 4: Exposure

Who is affected

Population	Status	Source
Alpine Linux 3.16 to 3.24 and edge, sshd without PAM	Affected under the four conditions; every release Alpine checked was affected	[13] (Confirmed)
Alpine tiny-cloud images (qcow2, VHD, AMI) 3.18.11 to 3.24.3	`alpine` user with `*` field and passwordless doas; exploitable with a path to root once a `$6$` hash exists; images from 3.21.10, 3.22.8, 3.23.8 and 3.24.4 carry the fix; running instances must be updated in place	[13] (Confirmed)
Alpine cloud images configured by cloud-init	Not affected: cloud-init writes `PasswordAuthentication no`	[13] (Confirmed)
Containers	Affected only if they run sshd under the conditions; Alpine-based images that run sshd are in scope	[13] (Confirmed); [50] (Reported)
Yocto, Buildroot, OpenWrt builds with OpenSSH on musl	Named by the researcher, Orca Security and SecurityWeek; Medcrypt reports reproducing on a stock Yocto image	[40] [50] [48] [9] (Reported)
OpenWrt images	Dropbear is not affected [7] (Confirmed); OpenWrt is in scope only where the openssh package, not Dropbear, serves SSH with password authentication on; OpenWrt's default SSH server was not checked against an OpenWrt primary, and no OpenWrt project advisory was found	[7] [22] [23] (Confirmed for the package update); Inferred for scope
Linux with glibc, or with PAM	Not affected	[2] (Confirmed)
Non-Linux systems, including OpenBSD and FreeBSD	Not affected; FreeBSD had published no advisory or VuXML entry	[2] [26] (Confirmed)
Dropbear and other non-OpenSSH password-login software	Not affected	[7] (Confirmed)

Vendor and project responses

Vendor or project	Response	Date	Source
OpenSSH	10.6p2	2026-11-05	[1] (Confirmed)
Alpine	Fixed packages: edge 10.6_p2-r0; 3.24 10.3_p1-r2; 3.23 10.2_p1-r1; 3.22 10.0_p1-r11; 3.21 9.9_p2-r1; 3.20 9.7_p1-r6; 3.19 9.6_p1-r3; 3.18 9.3_p2-r4; 3.17 9.1_p1-r7; 3.16 9.0_p1-r6	2026-11-05	[13] (Confirmed)
Gentoo	Bug 985742; openssh 10.6_p2 added	2026-11-05	[20] (Confirmed)
Void Linux	openssh 10.6p2	2026-11-05	[21] (Confirmed)
OpenWrt packages feed	openssh 10.6_p2	2026-11-05	[22] [23] (Confirmed)
Buildroot	Security bump to 10.6p2	2026-11-05	[24] (Confirmed)
OpenEmbedded-Core (Yocto)	Upgrade 10.6p1 to 10.6p2	2026-11-06	[25] (Confirmed)
Home Assistant Terminal & SSH app	10.6.0 with Alpine's fixed package; the changelog says the default setup should not be exploitable even with password authentication on	2026-11-05	[28] (Confirmed)
Community Home Assistant SSH add-on	v24.2.1 with Alpine's fixed package	2026-11-05	[29] (Confirmed)
linuxserver openssh-server image	`10.3_p1-r2-ls242`	2026-11-05	[30] (Confirmed; fix inferred from the version match)
panubo/docker-sshd	Issue #93 asking for 10.6p2, still open when checked	2026-11-07	[31] (Confirmed)
Coolify	Hardening proposal: the installer's Alpine branch starts sshd without disabling password authentication; not filed as a Coolify vulnerability	2026-11-07	[32] (Reported)
Debian	sid and forky fixed in 1:10.6p2-1; bookworm and trixie listed vulnerable with no DSA; urgency unimportant	checked 2026-11-11	[17] (Confirmed)
Ubuntu	Not affected, 14.04 to 26.10: glibc and PAM; priority High because of KEV	2026-11-06	[18] (Confirmed)
Red Hat	Not affected (RHEL 6 to 10, OpenShift, Hardened Images): glibc and PAM; Bugzilla 2567690	checked 2026-11-11	[15] (Confirmed)
SUSE	Every listed SLES, SLE Micro and openSUSE Leap product Not affected; Bugzilla 1289644 RESOLVED/INVALID; TID-SSHHOLE	2026-11-08	[19] (Confirmed)
Synology	Synology-SA-26:16: DSM, SRM, BeeStation OS and APM not affected	2026-11-06	[27] (Confirmed)
FreeBSD	No advisory or VuXML entry	checked 2026-11-11	[26] (Confirmed)

How many hosts

Four web searches on 11 November 2026 found no internet-wide SSHole exposure count from Shadowserver, Censys or Shodan, and none of the press or vendor pages opened quotes one; the scanners' own dashboards were not checked (Inferred). A banner count would mislead anyway: Alpine backported the fix into older version strings, so a banner below 10.6p2 does not by itself mean a host is vulnerable (Inferred from [13]). Orca Security, BleepingComputer and SecurityWeek likewise give no count (**Reported** [50] [46] [48]).

For scale, the 2024 regreSSHion flaw, which affected default glibc builds, drew a Qualys estimate of over 14 million potentially vulnerable internet-facing OpenSSH instances (**Reported** [55]). SSHole's install base is far smaller, yet it is the one in KEV (Inferred [35]; see Part 7).

Part 5: The vulnerability-management view

Where the advisory lived

The OpenSSH security page, as opened on 11 November, had no entry newer than 9 April 2025 (**Confirmed** [5]). The bypass appears only in the release notes, so a team that watches only the security page would have missed it (Inferred from [5] [1]). The 10.6p2 notes also say the team is receiving many AI-assisted bug reports, has seen AI-found bugs rediscovered independently, and will make more frequent releases instead of batching fixes (**Confirmed** [1]). Feeds that key on the release notes, the CVE record and KEV will see these releases sooner (Inferred).

Scores and weaknesses, side by side

Record	Score	Weakness	Note	Source
CVE record (MITRE CNA)	8.1 High, AC:H	CWE-394	Affected: vendor OpenBSD, product OpenSSH, platform Linux, versions below 10.6p2	[10] (Confirmed)
NVD	CNA 8.1 as Secondary; no NVD primary score	CWE-394	CPE: OpenSSH below 10.6p2 running on Alpine Linux before 3.21.10, 3.22.8, 3.23.8 and 3.24.4	[11] (Confirmed)
GHSA-4fcc-vm97-gx3x	High, 8.1	CWE-394	Unreviewed	[12] (Confirmed)
Red Hat	Critical, draft 9.8, AC:L	CWE-303	Products not affected	[15] (Confirmed)
KEV	n/a	CWE-394	"OpenBSD OpenSSH Unexpected Status Code or Return Value Vulnerability"	[34] (Confirmed)
CISA ADP SSVC	Exploitation active, Automatable no, Technical Impact total	n/a	Date-only timestamp 5 November; container updated 10 November	[10] (Confirmed)

False positives and false negatives

- **False positives from version matching.** The CPE range is "OpenSSH before 10.6p2" with a platform condition, so scanners that match on version alone will flag Debian, Ubuntu and RHEL hosts that cannot be exploited; triage has to key on the libc, PAM use and the `PasswordAuthentication` setting (Inferred from [10] [11] [15] [18]). Debian's "vulnerable" rows at urgency "unimportant" and Ubuntu's High priority on a Not affected package are the same signal seen from the distribution side (**Confirmed** [17] [18]).
- **False negatives from the CPE set.** NVD's CPE configuration names only Alpine, so CPE-driven scanners will not flag Yocto, Buildroot or appliance builds of musl sshd without PAM; embedded fleets depend on device makers shipping 10.6p2 or a backport (Inferred from [11] [9]).
- **Backported versions.** Alpine's fixed packages for older branches keep their older version numbers (for example 3.24's 10.3_p1-r2), so a version-only rule also misses fixed hosts in the other direction (Inferred from [13]).
- **A same-week errata that is not the fix.** RHSA-2026:97866 (Moderate, RHEL 9, 10 November) fixes CVE-2026-59997, CVE-2026-59998 and CVE-2026-60000, not CVE-2026-123158, and must not be read as an SSHole response (**Confirmed** [16]).
- **Scanner support.** google/goonami-scanner added the CVE id to its existing `opensshauthbypass` detector on 5 November (**Confirmed** [33]).

KEV, BOD 26-04 and the three-day clock

BOD 26-04, issued 10 June 2026, supersedes BOD 19-02 and BOD 22-01 and sets remediation urgency from four inputs: public exposure, KEV status, whether an adversary can automate exploitation, and technical impact (**Confirmed** [37]). Its Table 1 gives 3 days plus forensic triage for an exposed, KEV-listed, not-automatable, total-control vulnerability (row 3), and 14 days when the system is not exposed (row 11) (**Confirmed** [37]). Removing a system from the internet flips the exposure input and pushes the timeline back (**Confirmed** [37]).

Applied to the CISA ADP values for SSHole, the table gives 3 days plus forensic triage for internet-facing hosts, which matches the KEV due date of 12 November, and 14 days for internal-only hosts (Inferred from [37] [10] [34]). A program running a 30-day KEV cycle would leave an internet-facing host open about 27 days past the federal deadline and about a month (32 days) after GreyNoise's first observed successful exploitation (Inferred). The KEV entry requires forensic triage and notes the flaw sits in an open-source component other products may use (**Confirmed** [34]).

Waiting for KEV starts late

The patch was public four days before the KEV listing, and sensor telemetry of exploitation came two to four days before it (Inferred from [1] [34] [41] [42] [43]). As opened on 11 November, the CISA ADP SSVC on the CVE record reads Exploitation active with a date-only 5 November timestamp, but the container was last updated on 10 November and cites the 8 November SANS diary and the 9 November KEV entry, so when "active" was first set is not established (**Confirmed** [10]). A queue triggered by the vendor advisory on 5 November would have started four days earlier than one triggered by KEV (Inferred). The TeamStarWolf Intelligence Hub feed carries the KEV row for the CVE dated 9 November and headline rows from 5 November onward (**Confirmed** [57]).

Part 6: The defender view

Fix

1. Upgrade to 10.6p2 or the patched distribution package (the Alpine package versions are in Part 4) (**Confirmed** [1] [13]).
2. Restart sshd. Upgrading the package does not replace the running daemon (**Confirmed** [13]).
3. Rebuilt images do not fix running instances: update tiny-cloud instances in place (**Confirmed** [13]), and treat long-lived containers that run sshd the same way (Inferred).

Bridge until the fix lands

- Set `PasswordAuthentication no` and restart sshd, after confirming that public-key login works and while keeping an existing session open; verify the effective configuration (**Confirmed** [13] [7]). Either updating or disabling password logins closes the hole (**Confirmed** [13]).
- Keep the default `PermitRootLogin prohibit-password`. It keeps a `root:*` account out of reach, but it does not help when another reachable account can escalate, for example through doas (**Confirmed** [13]).
- Lock accounts that should never log in with `!` rather than `*` (Inferred from Alpine's not-affected list [13]).
- Restrict SSH exposure (remove it from the internet, use a jump host, allow-list source ranges). This changes the BOD 26-04 exposure input and limits attackers to internal sources, but the flaw stays exploitable from any host that can reach port 22 (Inferred from [37]); none of the opened primaries names jump hosts specifically.

Detect

- **Logs.** Look for sshd "Accepted password" lines for accounts that have no password (`alpine`, root, key-only users) (**Confirmed** [13]).
- **Host review.** Review doas use, recently created users, recently changed files and authorized keys; if a login cannot be ruled out, treat the host as compromised (**Confirmed** [13]).
- **Persistence artifacts.** Look for unauthorized SSH keys, the TAC Agent and its Python runtime, and unexpected startup services, the artifacts GreyNoise reports attackers left (Inferred from [41] [46]).
- **Session fingerprints.** GreyNoise publishes HASSH client fingerprints, notes a Paramiko-tagged exploit client, and flags `sshd-session` spawning `sh` (**Reported** [41]).
- **Blocking.** One command-and-control address GreyNoise saw is shared Cloudflare space, so block the domain rather than the address; some attacking addresses may be compromised legitimate infrastructure (**Reported** [41]).

Telling an attempt from a compromise

A long password in a log is not proof of SSHole. SANS saw long-password entries on 1 November, before disclosure, from buggy brute-force scripts pasting shell commands into the password field, and its Cowrie honeypots keep only the first 255 characters, so password-length alerts on such sensors cannot by themselves separate SSHole attempts from other junk (**Reported** [42]). Because SSH is encrypted, GreyNoise says exploitation is hard to confirm from traffic, and its confirmed counts rest on observed shell commands (**Reported** [41]). The reliable signal is on the host: a successful password login for an account that has no password (**Confirmed** [13]).

Triage after a suspected login

The KEV entry requires forensic triage under CISA's requirements (**Confirmed** [34]). Given what GreyNoise reports attackers did after login, a triage should cover authorized keys for every account (root and `alpine` in particular), new local accounts and doas rules, startup services, DNS configuration, new SSH servers or listeners, Python runtimes and agents, outbound HTTPS beacons, cloud metadata access, and any credential or private key the host could read (Inferred from [41] [46]). Rotate those credentials and keys, and rebuild where a login cannot be ruled out (Inferred from [13]).

Part 7: The lineage

SSHole joins a line of OpenSSH and Alpine flaws whose lessons recur.

Year	CVE	What it was	Lesson	Source
2016	CVE-2016-6210	Long-password timing let an attacker tell valid account names from invalid ones; fixed in 7.3, which also capped password length at 1024 characters. The researcher and press trace SSHole to this fix's fake-salt handling	A defensive fix can carry a new assumption	[1] (Confirmed); [40] [45] [44] (Reported, for the trace)
2016	CVE-2016-10009	ssh-agent loaded PKCS#11 modules from untrusted paths through a forwarded agent socket; reported by Jann Horn; 7.4 added a trusted-path allow-list; NVD CWE-426, CVSS 7.3	Agent forwarding extends trust to the remote host	[52] (Confirmed)
2019	CVE-2019-5021	Official Alpine Docker images since 3.3 shipped a NULL root password, a regression from December 2015; NVD CWE-258, CVSS 9.8. The researcher says Alpine's later change of root's field from `!` to `*` is part of SSHole's chain	Shadow placeholder values carry security meaning	[53] (Confirmed); [40] (Reported, for the link)
2023	CVE-2023-38408	ssh-agent PKCS#11 remote code execution through a forwarded agent, found by Qualys; 9.3p2 refuses remote PKCS#11 load requests by default; 5.5 to 9.3p1 affected	A path allow-list is not a behavior allow-list	[1] [5] (Confirmed)
2024	CVE-2024-6387, regreSSHion	Pre-authentication signal-handler race in default sshd, a regression of CVE-2006-5051 reintroduced in 8.5p1; 8.5p1 to 9.7p1 affected; demonstrated on 32-bit glibc with ASLR in 6 to 8 hours on average; OpenBSD not vulnerable	Regression testing for old security fixes	[54] (Confirmed)

Year	CVE	What it was	Lesson	Source
2024	CVE-2024-6409	Related signal-handler race in the privsep child; OpenSSH 8.7 and 8.8 and builds carrying Red Hat's audit patch (RHEL 9 and rebuilds, some Fedora 35 to 37); not proven exploitable	Downstream distribution patches carry their own pre-authentication risk	[56] (Confirmed)
2026	CVE-2026-123158, SSHole	musl `crypt()` error token matched a passwordless account's field when sshd ran without PAM	A caller must check what a library's return value means, not only whether it matches	This study

For regreSSHion, Qualys found over 14 million potentially vulnerable internet-facing OpenSSH instances by searching Censys and Shodan, and separately about 700,000 vulnerable external instances in its own customer data, 31 percent of internet-facing OpenSSH there; the two figures use different methods and should not be combined (**Reported** [55]).

The pattern across the lineage: regreSSHion and CVE-2024-6409 depended on glibc, while SSHole is the mirror image, dependent on musl and safe on glibc. All three turn on libc behavior that sshd assumed. SSHole is the only OpenSSH flaw in KEV, and so the only one in this lineage that CISA lists as known exploited, even though its install base is far smaller (**Confirmed** [35] for the KEV fact; Inferred for the comparison). KEV lists none of CVE-2024-6387, CVE-2024-6409, CVE-2023-38408 or CVE-2016-10009 (**Confirmed** [35]).

Another sshd authentication story, the 2024 XZ Utils backdoor, is told in its own study.

Part 8: MITRE mappings

This Part binds the verified record to MITRE ATT&CK v20.0, CWE, CAPEC and D3FEND. Every id was checked against the live ATT&CK page or the library's data files on 11 November 2026 [58] to [67]. No advisory in the record names ATT&CK ids, so every technique mapping below is this study's own and is graded Inferred; the id, name and tactics are Confirmed. SSHole is an Enterprise vulnerability on Linux; there is no ATT&CK for ICS or Mobile mapping in the record.

ATT&CK Enterprise techniques

Id	Name	Tactic (v20.0)	Where it appears in the SSHole record	Source
T1190	Exploit Public-Facing Application	Initial Access	The network-reachable sshd bypass: CVE record (5 Nov), Alpine advisory (5 Nov), KEV (9 Nov)	[10] [13] [34] [58]
T1133	External Remote Services	Initial Access, Persistence	Internet-exposed SSH as the entry point and for return access; GreyNoise post-exploitation (7 to 10 Nov). ATT&CK's description names VPN, Citrix, WinRM and VNC; SSH appears in its procedure examples and analytics	[13] [41] [59]
T1078.003	Local Accounts	Initial Access, Persistence, Privilege Escalation, Stealth	The login lands as an existing local account (`alpine`, root, key-only users): Alpine advisory (5 Nov)	[13] [60]
T1078.001	Default Accounts	Initial Access, Persistence, Privilege Escalation, Stealth	The `alpine` user shipped in tiny-cloud images 3.18.11 to 3.24.3, and `root:*`: Alpine advisory (5 Nov)	[13] [65]
T1098.004	SSH Authorized Keys	Persistence, Privilege Escalation	Attacker keys added to root and `alpine` authorized keys, 8 to 10 Nov (GreyNoise)	[41] [46] [61]
T1136.001	Local Account	Persistence	New local account with a doas rule, 10 Nov (GreyNoise)	[41] [62]
T1548.003	Sudo and Sudo Caching	Privilege Escalation	Passwordless doas on the tiny-cloud `alpine` user (Alpine, 5 Nov) and doas rules added after login (GreyNoise, 7 to 10 Nov). The ATT&CK page does not mention doas, so this mapping is an analogy	[13] [41] [64]
T1003.008	/etc/passwd and /etc/shadow	Credential Access	doas attempts to read the shadow file from 7 Nov (GreyNoise); password-hash reads (BleepingComputer, 9 Nov)	[41] [46] [63]
T1552.004	Private Keys	Credential Access	Attempts to read root SSH keys (BleepingComputer citing GreyNoise, 9 Nov)	[46] [65]
T1552.005	Cloud Instance Metadata API	Credential Access	Cloud metadata queries (GreyNoise; BleepingComputer, 9 Nov)	[41] [46] [65]
T1059.004	Unix Shell	Execution	`sshd-session` spawning `sh` (GreyNoise); commands over non-interactive sessions (The Hacker News, 6 Nov)	[41] [45] [65]
T1082	System Information Discovery	Discovery	Host, network, process and SSH-configuration discovery (GreyNoise, 7 to 11 Nov); reconnaissance on Previdian's honeypot (6 Nov)	[41] [44] [65]
T1033	System Owner/User Discovery	Discovery	Discovery commands after login (The Hacker News, 6 Nov)	[45] [65]
T1105	Ingress Tool Transfer	Command and Control	GT10's staged Python runtime and TAC Agent (GreyNoise, 7 to 10 Nov)	[41] [65]
T1595.002	Vulnerability Scanning	Reconnaissance	Mass scanning and exploitation attempts on sensor networks (GreyNoise, SANS ISC, 5 to 11 Nov)	[41] [42] [65]

Id	Name	Tactic (v20.0)	Where it appears in the SSHole record	Source
T1110.001	Password Guessing	Credential Access	Background only: SANS's pre-disclosure long-password entries from brute-force scripts (1 Nov). Not SSHole exploitation, and left out of the layer	[42] [65]

Left out for want of support: Systemd Service and RC Scripts (GreyNoise says "startup service" without naming the mechanism), Application Layer Protocol sub-techniques (the agent's protocol is described only as HTTPS polling), and T1021.004 SSH as lateral movement (no lateral movement is reported) (Inferred). The detection strategies ATT&CK records for the core techniques are DET0080 (T1190), DET0354 (T1133), DET0407 (T1078.003), DET0126 (T1098.004), DET0447 (T1136.001), DET0446 (T1003.008) and DET0052 (T1548.003) (**Confirmed** [58] to [64]).

ATT&CK groups, software and campaigns

None. No opened primary names a threat actor, and GreyNoise's GT10 and TAC Agent are vendor labels with no ATT&CK id, so no group, software or campaign page is linked (Inferred [41]). Pinning the activity to any group in the Threat Actors reference would overstate the record.

CWE and CAPEC

Weakness	Name	Who assigns it	CAPEC in the library	Source
CWE-394	Unexpected Status Code or Return Value	MITRE CNA on the CVE record; NVD; KEV; GHSA-4fcc-vm97-gx3x	None: the library's `data/weaknesses/cwe.jsonl` gives CWE-394 no related CAPEC entries, so no CAPEC is bound	[10] [11] [34] [12] [66]
CWE-303	Incorrect Implementation of Authentication Algorithm	Red Hat only	Not bound: recorded as a disagreement with the CNA	[15]

The library has no generated CWE pages; the CWE Reference and CAPEC Reference cover the classes.

D3FEND countermeasures

Countermeasure	Id	Library mappings to this study's techniques	SSHole guidance it matches	Source
Local Account Monitoring	D3-LAM	T1078.003, T1136.001	Reviewing new users and password logins to no-password accounts (Alpine)	[67] [13]
Account Locking	D3-AL	T1078.001, T1078.003, T1136.001	Locking accounts with `!` instead of `*` (Inferred pairing)	[67] [13]
Remote Terminal Session Detection	D3-RTSD	T1190, T1105 (and T1021.004)	`sshd-session` spawning a shell (GreyNoise)	[67] [41]
Protocol Metadata Anomaly Detection	D3-PMAD	T1190, T1105 (and T1021.004)	HASSH client fingerprints (GreyNoise)	[67] [41]
User Geolocation Logon Pattern Analysis	D3-UGLPA	T1190, T1105 (and T1021.004)	Logins from unexpected networks (Inferred pairing)	[67]
Inbound Session Volume Analysis	D3-ISVA	T1190	Port-22 session volume on sensors (GreyNoise), with the caveat that volume is not compromise	[67] [41]
Session Termination	D3-ST	T1133 (and T1021.004)	Ending suspect SSH sessions during triage (Inferred pairing)	[67]
File Integrity Monitoring	D3-FIM	T1003.008, T1033, T1548.003	Watching authorized keys, doas configuration and startup services (Alpine, GreyNoise)	[67] [13] [41]
Credential Rotation	D3-CRO	T1003.008	Rotating credentials and keys a compromised host could read (Inferred pairing)	[67]
Software Update	D3-SU	Not mapped to these techniques	Upgrading to 10.6p2 and restarting sshd (Inferred pairing)	[67] [1] [13]
Application Configuration Hardening	D3-ACH	Not mapped to these techniques	`PasswordAuthentication no` (Inferred pairing)	[67] [13]
User Session Init Config Analysis	D3-USICA	Not mapped to these techniques	Reviewing startup services added after login (Inferred pairing)	[67] [41]

T1098.004 SSH Authorized Keys has no D3FEND mapping in the library's data (**Confirmed** [67]). Software Update and Application Configuration Hardening are the two countermeasures the advisories actually prescribe, yet the library maps neither to these techniques, so pairing them with SSHole is this study's reading (Confirmed for the data [67]; Inferred for the pairing).

Navigator layer

The study's techniques are saved as an ATT&CK Navigator layer, navigator/library-layers/sshole-cve-2026-123158.json, listed on the Navigator layers page. It is pinned to ATT&CK v20 and scores each technique by the strength of its tie to SSHole: 75 for the initial-access path the CVE record and the Alpine advisory describe, 50 for post-exploitation behavior reported by sensor operators and the press, and 25 for the doas analogy under Sudo and Sudo Caching. Password Guessing is left out because it is background noise, not SSHole. Each entry's comment names the source numbers above.

Cross-cutting themes

- **The embargo is shrinking.** OpenSSH fixed and shipped within about a day of learning of the bug and said AI agents had rediscovered bugs within hours (**Confirmed** [2] [4]). A public exploit appeared before the CVE id existed (**Reported** [41]). Programs whose intake starts at a CVE id or a KEV listing start late; intake has to watch release notes and mailing lists too (Inferred). See the AI Threats 2026 case study and the CVE-2026-98432 case study for the same pressure from the exploit side.
- **The interface between libraries is a security boundary.** A C library returned an error token; a caller compared it as a hash; a shadow-file convention made the two collide (**Confirmed** [13] [7] [8]). Each party can say the root cause is elsewhere; OpenSSH and Alpine shipped changes, and musl plans one (**Confirmed** [1] [13] [7]; Inferred for the reading).
- **The same CVE means different things on different hosts.** A Critical 9.8 on a platform that is not affected, a "vulnerable" row at "unimportant" urgency, and a High priority on a Not affected package all describe the same CVE (**Confirmed** [15] [17] [18]). Context (libc, PAM, configuration, exposure) changes the risk more than the score does, which is the argument of the Vulnerability Prioritization Reference (Inferred).
- **Defaults decide exposure.** Password authentication on by default, root shipped as `*`, a convenience user with passwordless doas, and cloud-init writing a safer default all moved hosts into or out of scope (**Confirmed** [13]). See the Linux Hardening Reference.
- **Embedded is where the long tail lives.** Distribution packages shipped within a day; Yocto, Buildroot and appliance builds patch on vendor firmware cycles and sit outside the CPE set (**Confirmed** [24] [25] [11]; Inferred for the tail). See the Firmware and IoT Security Reference.
- **Patch the daemon, not just the package.** Alpine's restart warning applies to every long-running service (**Confirmed** [13]).

What is overstated and what is understated

- **Overstated: exploitation within hours.** Exploitation attempts appeared about 8 hours after CVE publication (Previdian) and on 5 November (SANS), and Previdian reported root on one Alpine honeypot on 6 November, but GreyNoise's first confirmed successful chain came about 32 hours after NVD publication, and every success reported is on a sensor or honeypot, not a named victim (**Reported** [43] [44] [42] [41]; Inferred for the comparison). Coverage that runs attempts and compromise together overstates both speed and reach.
- **Overstated: scan volume as attacks.** The 27.5 million to 45.5 million port-22 figures are general SSH background, not SSHole exploitation; GreyNoise itself counts 5 possible exploitation attempts among 33.7 million sessions (**Reported** [41] [46]; Inferred for the reading). Every confirmed chain is on a sensor network, not a named victim (Inferred [41]).
- **Overstated: all of OpenSSH on Linux, and root on any Alpine box.** Red Hat, Ubuntu and SUSE say their glibc and PAM builds are not affected, and the CVE is scoped to musl without PAM (**Confirmed** [15] [18] [19] [10]). Alpine root is protected by the default `PermitRootLogin prohibit-password`; root comes through the tiny-cloud user's passwordless doas or a changed setting (**Confirmed** [13]).
- **Overstated: tracker severity.** Red Hat's 9.8 on a platform it calls not affected, and version-only scanner hits on glibc hosts, inflate the scope (**Confirmed** [15]; Inferred for the scanner effect).

- **Overstated: attribution.** Chinese-language comments in one cluster's agent are an artifact, not attribution; no primary names an actor (Inferred [41]).
- **Understated: embedded and appliance fleets.** Medcrypt's Yocto reproduction and the "hardened" embedded baseline sit outside NVD's CPE set and outside distribution advisories (**Reported** [9]; Inferred from [11]).
- **Understated: running cloud instances.** Tiny-cloud instances built from 3.18.11 to 3.24.3 stay exploitable until each is updated, and rebuilding the image does not fix them (**Confirmed** [13]).
- **Understated: persistence after patching.** CISA requires forensic triage, and GreyNoise saw authorized keys and new local accounts within days; a host patched after exposure can still carry a planted key (**Confirmed** [34]; **Reported** [41]).
- **Understated: the KEV clock.** A three-day window is short, and it began four days after the patch (**Confirmed** [34] [1]; Inferred for the reading).

Sources

All sources were opened on 11 November 2026. Grades apply to the source as used here.

#	Source	URL	Opened	Grade
1	OpenSSH, Release notes (10.6p2 and earlier releases)	openssh.org/releasenotes.html#10.6p2	2026-11-11	Confirmed
2	Damien Miller, "urgent security release: 10.6p2", openssh-unix-dev, 5 Nov 2026	marc.info/?l=openssh-unix-dev&m=179388064263131	2026-11-11	Confirmed
3	Damien Miller, Mastodon announcement, 5 Nov 2026	hachyderm.io/@damienmiller/117563026759098135	2026-11-11	Confirmed
4	openssh-portable commit 4353fdc, "avoid password authn bypass"	github.com/openssh/openssh-portable/commit/4353fdc...	2026-11-11	Confirmed
5	OpenSSH, Security page	openssh.org/security.html	2026-11-11	Confirmed
6	Jan Schaumann, "sshole": password authentication bypass: OpenSSH + musl libc, oss-security, 5 Nov 2026	openwall.com/lists/oss-security/2026/11/05/3	2026-11-11	Confirmed
7	Rich Felker, musl advisory, musl list, 5 Nov 2026	openwall.com/lists/musl/2026/11/05/4	2026-11-11	Confirmed
8	Rich Felker, follow-up on the crypt failure token, musl list, 6 Nov 2026	openwall.com/lists/musl/2026/11/06/7	2026-11-11	Confirmed
9	Vidya Murthy (Medcrypt), independent reproduction, oss-security, 9 Nov 2026	openwall.com/lists/oss-security/2026/11/09/27	2026-11-11	Reported
10	CVE record CVE-2026-123158 (MITRE CNA, with the CISA ADP container)	cveawg.mitre.org/api/cve/CVE-2026-123158; cve.org/CVERecord?id=CVE-2026-123158	2026-11-11	Confirmed
11	NVD, CVE-2026-123158 (detail page and API)	nvd.nist.gov/vuln/detail/CVE-2026-123158; services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2026-123158	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
12	GitHub Advisory Database, GHSA-4fcc-vm97-gx3x	github.com/advisories/GHSA-4fcc-vm97-gx3x	2026-11-11	Confirmed
13	Alpine Linux, OpenSSH password authentication bypass, 5 Nov 2026	alpinelinux.org/posts/2026-11-05-openssh-password-authentication-bypass/	2026-11-11	Confirmed
14	Alpine Linux, Alpine 3.21.10, 3.22.8, 3.23.8 and 3.24.4 released, 5 Nov 2026	alpinelinux.org/posts/alpine-3.21.10-3.22.8-3.23.8-3.24.4-released/	2026-11-11	Confirmed
15	Red Hat, CVE-2026-123158	access.redhat.com/security/cve/CVE-2026-123158	2026-11-11	Confirmed
16	Red Hat, RHSA-2026:97866	access.redhat.com/errata/RHSA-2026:97866	2026-11-11	Confirmed
17	Debian security tracker, CVE-2026-123158	security-tracker.debian.org/tracker/CVE-2026-123158	2026-11-11	Confirmed
18	Ubuntu, CVE-2026-123158	ubuntu.com/security/CVE-2026-123158	2026-11-11	Confirmed
19	SUSE, CVE-2026-123158	suse.com/security/cve/CVE-2026-123158.html	2026-11-11	Confirmed
20	Gentoo Bugzilla, bug 985742	bugs.gentoo.org/985742	2026-11-11	Confirmed
21	Void Linux, openssh template history	github.com/void-linux/void-packages/commits/master/srcpkgs/openssh/template	2026-11-11	Confirmed
22	OpenWrt packages feed, openssh Makefile history	github.com/openwrt/packages/commits/master/net/openssh/Makefile	2026-11-11	Confirmed
23	OpenWrt packages commit 92643a05ce, "openssh: update to 10.6_p2"	github.com/openwrt/packages/commit/92643a05ce	2026-11-11	Confirmed
24	Buildroot commit 87eceac257, "package/openssh: security bump version to 10.6p2"	github.com/buildroot/buildroot/commit/87eceac257	2026-11-11	Confirmed
25	OpenEmbedded-Core commit 5247d0d886, "openssh: upgrade 10.6p1 -> 10.6p2"	github.com/openembedded/openembedded-core/commit/5247d0d886	2026-11-11	Confirmed
26	FreeBSD VuXML index	vuxml.freebsd.org/freebsd/index.html	2026-11-11	Confirmed
27	Synology, Synology-SA-26:16 OpenSSH (sshole), 6 Nov 2026	synology.com/en-global/security/advisory/Synology_SA_26_16	2026-11-11	Confirmed
28	Home Assistant add-ons commit 0155117095 (Terminal & SSH 10.6.0)	github.com/home-assistant/addons/commit/0155117095	2026-11-11	Confirmed
29	Home Assistant Community Add-ons, SSH add-on releases	github.com/hassio-addons/addon-ssh/releases	2026-11-11	Confirmed
30	linuxserver, docker-openssh-server releases	github.com/linuxserver/docker-openssh-server/releases	2026-11-11	Confirmed
31	panubo/docker-sshd, issue #93	github.com/panubo/docker-sshd/issues/93	2026-11-11	Confirmed
32	Coolify, discussion #12484	github.com/coollabsio/coolify/discussions/12484	2026-11-11	Reported
33	google/goonami-scanner, PR #277	github.com/google/goonami-scanner/pull/277	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
34	CISA, Known Exploited Vulnerabilities catalog entry for CVE-2026-123158	cisa.gov/known-exploited-vulnerabilities-catalog?field_cve=CVE-2026-123158	2026-11-11	Confirmed
35	CISA, KEV catalog JSON feed (catalog version 2026.11.10)	cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json	2026-11-11	Confirmed
36	CISA, CISA Adds Four Known Exploited Vulnerabilities to Catalog, 9 Nov 2026	cisa.gov/news-events/alerts/2026/11/09/cisa-adds-four-known-exploited-vulnerabilities-catalog	2026-11-11	Confirmed
37	CISA, BOD 26-04, Prioritizing Security Updates Based on Risk, 10 Jun 2026	cisa.gov/news-events/directives/bod-26-04-prioritizing-security-updates-based-risk	2026-11-11	Confirmed
38	Canadian Centre for Cyber Security, AV26-1130	cyber.gc.ca/en/alerts-advisories/openbsd-security-advisory-av26-1130	2026-11-11	Confirmed
39	HKCERT, OpenSSH multiple vulnerabilities bulletin, 6 Nov 2026	hkcert.org/security-bulletin/openssh-multiple-vulnerabilities_20261106	2026-11-11	Confirmed
40	Ozgun Kultekin, researcher write-up	sshhole.com	2026-11-11	Reported
41	GreyNoise, SSHole event tracker (updated 11 Nov 2026 05:10 UTC)	sshole.events.greynoise.io	2026-11-11	Reported
42	SANS ISC, diary 33498 (Johannes Ullrich), 8 Nov 2026	isc.sans.edu/diary/33498	2026-11-11	Reported
43	Previdian, CVE-2026-123158	previdian.com/CVE-2026-123158	2026-11-11	Reported
44	Help Net Security, SSHole exploitation report, 6 Nov 2026	helpnetsecurity.com/2026/11/06/openssh-sshole-cve-2026-123158-exploitation/	2026-11-11	Reported
45	The Hacker News, Hackers exploited OpenSSH SSHole flaw, 6 Nov 2026, updated 8 Nov	thehackernews.com/2026/11/hackers-exploited-openssh-sshole-flaw.html	2026-11-11	Reported
46	BleepingComputer, Hackers exploit SSHole OpenSSH flaw to breach Linux systems, 9 Nov 2026	bleepingcomputer.com/news/security/hackers-exploit-sshole-openssh-flaw-to-breach-linux-systems/	2026-11-11	Reported
47	SecurityWeek, OpenSSH rushes patches for SSHole authentication bypass, 6 Nov 2026	securityweek.com/openssh-rushes-patches-for-sshole-authentication-bypass/	2026-11-11	Reported
48	SecurityWeek, Hackers exploiting SSHole authentication bypass in OpenSSH, 9 Nov 2026	securityweek.com/hackers-exploiting-sshole-authentication-bypass-in-openssh/	2026-11-11	Reported
49	Check Point Research, 9th November threat intelligence report	research.checkpoint.com/2026/9th-november-threat-intelligence-report/	2026-11-11	Reported
50	Orca Security, SSHole research post	orca.security/resources/research/sshole-openssh-authentication-bypass-...	2026-11-11	Reported
51	leonjza/sshhole-lab repository (existence and creation date only; contents not reviewed)	github.com/leonjza/sshhole-lab	2026-11-11	Confirmed
52	NVD, CVE-2016-10009	nvd.nist.gov/vuln/detail/CVE-2016-10009	2026-11-11	Confirmed
53	NVD, CVE-2019-5021	nvd.nist.gov/vuln/detail/CVE-2019-5021	2026-11-11	Confirmed
54	Qualys, regreSSHion advisory (CVE-2024-6387), 1 Jul 2024	qualys.com/2024/07/01/cve-2024-6387/regresshion.txt	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
55	Qualys, regreSSHion blog post, 1 Jul 2024	blog.qualys.com/vulnerabilities-threat-research/2024/07/01/regresshion-...	2026-11-11	Reported
56	Solar Designer, CVE-2024-6409, oss-security, 8 Jul 2024	openwall.com/lists/oss-security/2024/07/08/2	2026-11-11	Confirmed
57	TeamStarWolf Intelligence Hub, feed	teamstarwolf.github.io/intelligence-hub/data/feed.json	2026-11-11	Confirmed
58	MITRE ATT&CK v20, T1190 Exploit Public-Facing Application	attack.mitre.org/techniques/T1190/	2026-11-11	Confirmed
59	MITRE ATT&CK v20, T1133 External Remote Services	attack.mitre.org/techniques/T1133/	2026-11-11	Confirmed
60	MITRE ATT&CK v20, T1078.003 Local Accounts	attack.mitre.org/techniques/T1078/003/	2026-11-11	Confirmed
61	MITRE ATT&CK v20, T1098.004 SSH Authorized Keys	attack.mitre.org/techniques/T1098/004/	2026-11-11	Confirmed
62	MITRE ATT&CK v20, T1136.001 Local Account	attack.mitre.org/techniques/T1136/001/	2026-11-11	Confirmed
63	MITRE ATT&CK v20, T1003.008 /etc/passwd and /etc/shadow	attack.mitre.org/techniques/T1003/008/	2026-11-11	Confirmed
64	MITRE ATT&CK v20, T1548.003 Sudo and Sudo Caching	attack.mitre.org/techniques/T1548/003/	2026-11-11	Confirmed
65	TeamStarWolf library data, `data/attack/technique_profiles.jsonl`	github.com/TeamStarWolf/TeamStarWolf/blob/main/data/attack/technique_profiles.jsonl	2026-11-11	Confirmed
66	TeamStarWolf library data, `data/weaknesses/cwe.jsonl`	github.com/TeamStarWolf/TeamStarWolf/blob/main/data/weaknesses/cwe.jsonl	2026-11-11	Confirmed
67	TeamStarWolf library data, `data/attack/technique_to_d3fend.jsonl` and `data/attack/d3fend_countermeasures.jsonl`, and the `mitre/d3fend/` pages	github.com/TeamStarWolf/TeamStarWolf/blob/main/data/attack/technique_to_d3fend.jsonl	2026-11-11	Confirmed

Could not be opened: watchTowr's and Defused's posts on X, cited only through SecurityWeek and BleepingComputer [48] [46]. Not reviewed by design: the public reproduction repositories [10] [51].

© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.

© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/

© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/

© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/

The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.

Related references

- CVE Reference, CWE Reference, CAPEC Reference, D3FEND Reference
- Threat Actors, Malware Families, Notable Incidents: no actor or malware family is attributed to this exploitation
- Vulnerability Prioritization Reference, Vulnerability Management Reference, Triage a CVE
- Linux Hardening Reference, Container Security Reference, Firmware and IoT Security Reference, Cloud Security Reference, Harden a Linux Host, Alpine Linux, SSH
- Incident Response Reference, Threat Hunting Reference, Detection Rules Reference
- Related case studies: The XZ Utils Backdoor, The CVE-2026-98432 Linux Kernel Flaw, The Multipath TCP Attack Surface, AI Threats 2026, Log4Shell, a library flaw inherited by every product that embeds it; Thirty Days of Exposure Checks, a month of KEV additions turned into per-host verdicts; GitLab CVE-2026-97229, another 2026 KEV listing with a three-day deadline
- Techniques: T1190 Exploit Public-Facing Application, T1133 External Remote Services, T1078.003 Local Accounts, T1078.001 Default Accounts, T1098.004 SSH Authorized Keys, T1136.001 Local Account, T1548.003 Sudo and Sudo Caching, T1003.008 /etc/passwd and /etc/shadow, T1552.004 Private Keys, T1552.005 Cloud Instance Metadata API, T1059.004 Unix Shell, T1082 System Information Discovery, T1033 System Owner/User Discovery, T1105 Ingress Tool Transfer, T1595.002 Vulnerability Scanning
- D3FEND: Local Account Monitoring, Account Locking, Remote Terminal Session Detection, File Integrity Monitoring, Credential Rotation, Software Update, Application Configuration Hardening, all countermeasures
- Navigator layers, including this study's layer, sshole-cve-2026-123158.json
- All case studies